

隐盾安全智能体 · 使用说明

面向涉密办公场景的本地化隐私防护桌面智能体 · V3.4.0 Yindun Security Agent — 让本地 AI 更安全、更智能、更可控

一、产品简介

隐盾安全智能体是一款常驻桌面的 AI 办公助手，核心差异在于**内置内存级隐私防护**：所有敏感信息（手机号、身份证、银行卡、密钥、病历、金额、人名等）在进入大模型之前，会在内存中自动替换为加密占位符；模型全程只见占位符，回答返回时再自动还原为明文呈现给你。

配合文件沙箱、权限分级、命令白名单、高危操作人工审批与哈希链审计，隐盾把“数据出网、落盘、留痕”三大泄露面逐一关闭，让你放心把涉密文档交给 AI 处理。

典型用途：合同/简历/病历等涉密文档的问答与摘要、本地知识库检索、项目代码分析、办公文件创建与整理、可追溯的操作审计。

二、安装与启动

界面说明：V3.3.2 起隐盾使用 Web 界面（窗口无系统边框，**拖动顶部条即可移动窗口、沿窗口边缘拖拽可改变大小**，右上角有最小化 / 置顶 / 关闭）。左侧是会话列表，中间是对话区，右侧是**可折叠的第三栏**（设置 / 审计 / 工作流三个页签）；顶栏两侧各有一个折叠按钮，收起后把空间让给对话。

三栏宽度可以自由调：把鼠标移到会话栏右边缘或面板左边缘（会出现一条细高亮线），按住拖动即可改变该栏宽度；**双击手柄**恢复默认宽度；手柄获得焦点后可用方向键微调（按住 Shift 步长更大）。宽度会自动记住，下次打开还是你调好的样子。范围上做了保护：会话栏 200–420px、面板 300–640px，且**对话区始终保留至少 420px**——窗口变窄时优先收窄两侧，再窄就自动把右栏收起来（窗口重新变宽会自动放回，这与“你自己手动收起”是两回事，手动收起不会被自动展开）。

闪发浮条（折叠模式）：点顶栏的折叠按钮，窗口会缩成一条浮条（贴着原窗口底边、水平居中）。在浮条里输入指令按回车，会**自动展开完整界面并把指令发出去**；浮条右侧常显一行状态（推理中.../已完成），不展开也知道有没有在跑；点浮条左侧的展开按钮或按 **Esc** 即可还原完整界面，窗口会精确回到折叠前的位置与大小。适合“只想顺手发一句、不想让窗口占地方”的场景。

置顶（悬浮于最上层）立即生效：点右上角的置顶按钮或设置里的「窗口始终置顶」开关，马上生效，不需要重启。

方式 A：免安装单文件 exe（推荐，双击即用）

1. 拿到 `隐盾安全智能体_V3.4.0_便携版.exe`（约 100+ MB，单文件）；
2. **双击直接运行**——无需安装、无需任何脚本、不需要管理员权限；
3. 首次启动约需 10~20 秒（单文件会先解压到临时目录，属正常现象），之后正常速度。

数据落在哪：配置、会话记录、审计日志、知识库向量数据都写在 **exe 同目录**，所以请把 exe 放在可写目录（桌面、文档、便携盘均可）。**卸载**：删除 exe 及其同目录下生成的数据文件即可，不留残余。

方式 B：源码运行（开发者）

```
# Python 3.10+, 安装依赖
pip install -r requirements.txt
python run.py
```

首次启动若被杀毒软件 / Windows Defender 提示，选择“仍要运行”或添加信任即可（未签名的绿色软件常见误报，源码可自查）。

三、首次使用：配置一个“算力底座”

隐盾需要接入一个大模型作为算力底座，**两种方式二选一**（约 2 分钟）。启动后看界面左上角状态灯：绿色圆点 + 模型名即已就绪；未就绪时点左下角齿轮图标进设置。

方式 A：本地离线模型（推荐，数据全程不出网）

1. 下载安装 Ollama：<https://ollama.com/download>（安装后服务自动运行）；
2. 打开命令行执行，拉取一个支持工具调用的模型：`bash ollama pull qwen2.5:7b-instruct`
如需使用知识库检索，再拉取向量模型：`bash ollama pull nomic-embed-text`
3. 启动隐盾，在设置页“算力底座 → 模型选择”中选中检测到的本地模型。

方式 B：云端模型（无需下载大文件）

1. 点左下角齿轮图标 → 「外部算力（OpenAI 兼容）」→ 填名称 / 模型 ID / 接口地址 / API Key → 添加；
2. 填入任一 OpenAI 兼容 API 的参数（示例：智谱开放平台）：
- `base_url`：`https://open.bigmodel.cn/api/paas/v4`
- `api_key`：你自己的密钥 - `model_id`：`glm-4-flash`
3. 保存后在模型下拉框选择该模型。

隐私提示：开启“隐私隔离网关”（默认开启）时，发往云端的内容已自动替换为占位符，真实敏感数据不出本地。

四、核心功能使用

4.1 对话与隐私脱敏

直接在底部输入框下达指令即可。含敏感信息的内容会先脱敏再交给模型，回答后自动还原。

- **快速 / 思考模式：**输入框上方切换。快速模式为只读安全模式（禁止一切写盘/删除/命令执行）；思考模式支持完整工具调用与多轮推理（思考深度 1-10 在设置页调节）。

- **挂载文件**：点"📎 挂载文件"上传 PDF / Word / Excel / TXT 等，直接在对话中就其内容提问。
- **会话管理**：💬 切换历史会话，➕ 新建会话；多会话相互隔离，记录加密存储。

4.2 本地知识库（脱敏 RAG）

在设置页底部"本地知识库"区，点"➕ 添加文档"将机密文档入库（入库即逐块脱敏，向量库中只存占位符，真实隐私永不落盘）。之后在对话中即可语义检索问答。

4.3 协同工作流

点左下角 workflow 图标进入工作流编排，内置合同审查 / 周报生成 / 代码安全检查等模板，支持步骤执行、审批通过与人工拦截；标记为「演示步骤」的环节目前返回模拟结果（界面已如实标注）。

- **实例重启不丢**：执行到一半（包括"等待人工审批"）的实例会自动保存，重启应用后原样恢复，可以接着审批、继续执行；执行中的步骤若因重启中断，会回到"待执行"而不是卡死。
- **周报数据真实**："收集工作记录"步骤读的是**真实审计日志**，审计为空就如实说为空，不再编造示例记录凑内容。
- **导出格式如实**：工作流报告可导出 Markdown / HTML / Word（兼容格式）/ JSON，以及插件提供的格式；不支持的格式（如 PDF）会明确报错并说明支持哪些，不会出现"步骤叫导出 PDF、产物却是 Markdown"的情况。

4.4 审计黑匣子

点左下角审计图标打开审计黑匣子：LLM 输入输出、工具调用、脱敏还原、审批决策逐条留痕，哈希链完整性状态实时可见，可导出 JSON / HTML 审计报告；面板内还提供「隐私健康体检」与「模型行为画像」。启用「导出格式扩展」插件后，导出菜单还会多出"Markdown 表格 / 卡片式 HTML"两种格式（菜单里会标明来源）。

关于"链校验未通过"：校验未通过时面板会直接写出**原因**（例如"尾部被截断" "锚点缺失" "第 N 条出现未受保护的旧版条目"），不是只给一个红叉。若原因是**锚点缺失**——通常出现在从旧版本升级、或把审计目录拷到另一台机器之后——面板会给出「重建锚点（接受当前链）」按钮：点它表示**你确认接受当前这份链作为新的信任起点**；确认之后，此前发生的尾部截断将无法再被发现，所以请先确认这份链确实没有被裁剪过再点。

4.5 插件（按需扩展能力）

设置页「插件（能力扩展）」区列出内置与用户安装的插件，默认全部关闭，需要时打开开关即可。每个插件卡片会写清：**它提供了什么能力**、来源（内置/用户安装）、网络权限、依赖是

否满足，以及自检状态；带词表的插件（如“自定义敏感词表”）可直接在卡片里编辑、保存即生效。

- **自定义敏感词表**：把项目代号、内部称谓、专用术语纳入脱敏。编辑词表文件，每行一条：普通词按字面匹配，`re:` 开头按正则，`#` 开头是注释。命中后送模型的是占位符，还原仍只在本机完成。
- **扩展附件解析**：让 `.eml` / `.html` / `.mht` 也能当附件挂载（纯标准库解析，不联网），解析出的文本与内核路径一样先脱敏再送模型。
- **办公 workflow 模板包**：给 workflow 补两个模板（代码安全体检增强版 / 本周工作总结）。其中“导出报告”这类高危步骤的审批由**内核强制**，插件无权降低审批强度。
- **导出格式扩展**：审计报告导出 Markdown 表格、workflow 报告导出卡片式 HTML。
- **审批决策提示**：审批弹窗出现后，用本地模型判断“这次操作与你刚才的请求是否相符”，结论异步补发到弹窗，仅供参考。
- **laya 风险分级**：审批弹窗再补一行风险分级（高危/中危/低危）：本机装了 laya 决策模型（`pip install laya`，重依赖按需安装）就用模型打分；没装、加载失败或推理失败时，自动回退到正则规则分级——默认规则开箱自带，`risk_rules.txt` 可在设置页直接编辑、改动立即生效；`backend.txt` 可强制只用模型或只用正则。无论哪条路径，提示都写明本次来源；推理与规则匹配全在本机、数据不出本机（注意：laya 首次加载需联网下载权重，涉密环境请预先离线导入；首次下载较慢时，插件只等 25 秒就主动改用正则规则给出提示，下载在后台继续，下一次审批自动用上模型）。

安全说明：插件是**本地代码**，隐盾不会联网下载插件；启用/停用、词表改动都会写入审计。插件的启用状态与自检结果都能在设置页看到——如果某个插件“启用了却没反应”，点一次「插件自检」即可定位（钩子函数名写错这类问题会被直接报出来）。

想自己写插件？见 [插件开发.md](#)：钩子契约、安全边界与最小示例都在里面。

五、安全机制说明

机制	作用
隐私 脱敏 网关	27 类敏感实体识别（正则粗筛 + 程序化精验），进模型前占位符化，映射表 Fernet 加密、密钥 DPAPI 保护
文件 沙箱	所有文件操作限定在沙箱目录内，越界读写一律拒绝
权限 分级	完全控制 / 安全只读 / 彻底审计 三档，按需收口写盘能力
命令 白名单	放行 python/pip/git/echo，去 shell 化执行，并做子命令级收口：python 仅允许执行沙箱内的 .py 脚本（ <code>-c</code> / <code>-m</code> / 标准输入等内联代码一律拒绝），pip/git 仅允许只读子命令（install/download/clone/fetch 等会触发代码执行或改动仓库的入口被拒绝）
熔断 审批	高危操作挂起后台线程，弹窗展示申请工具、目标路径与即将执行的命令 / 即将写入的内容，人工二次确认后才放行；超时自动驳回
哈希 链审计	HMAC-SHA256 链式存储，篡改即告警；另设 HMAC 链锚点 （条数+链头，存放于密钥旁的用户目录）以发现"整链改写"与"尾部截断"；审计自身只存脱敏预览

六、数据与隐私

- **配置**：程序目录下 `global_config.json`（模型、权限、界面等；免安装版即 exe 同目录）。
- **会话**： `chat_sessions.json`，内容加密存储。
- **审计**： `audit_logs/`，哈希链防篡改，仅存脱敏预览。
- **知识库**： `data/knowledge_base/`，只存占位符向量（元数据只留文件名，不写本机路径）。
- **用户目录**（`%APPDATA%\Yindun\`）：只有两样东西——脱敏主密钥（Windows DPAPI 按当前用户保护）与**审计链锚点**（`audit_chain.anchor.<审计目录指纹>.json`，用于发现"整链改写/尾部截断"）。这两样刻意放在用户目录而不是程序目录：**不能与它们要保护的数据同盘**，否则"删掉密钥/锚点"就能绕过保护。也因此它们不随 exe 移动（换机器后旧审计链需要重新确认，见 4.4）。

- 免安装版：删除 exe 与其同目录生成的数据即可；如需彻底清除，再删除上述用户目录下的 `Yindun\` 文件夹。安装版：卸载即清除程序目录数据，用户目录同上。
-

七、常见问题 (FAQ)

- **状态栏显示"模型初始化失败"**：未装 Ollama 或未拉取模型，按第三节方式 A 完成，或改用方式 B。
 - **杀毒软件报警**：未签名绿色软件常见误报，添加信任即可。
 - **想让 AI 写文件却提示"快速模式无法执行"**：切到"思考"模式再试。
 - **回答里出现 `[PHONE_0_xxxx]` 这类占位符没还原**：属跨轮历史占位符，正常会随会话映射还原；若长期不还原，可在设置页关闭再开启"隐私隔离网关"重置会话。
 - **换了电脑/重装系统后旧会话无法还原明文**：脱敏密钥绑定 Windows 用户账户 (DPAPI)，属安全优先于可恢复性的既定设计。
-

八、版本与声明

- 当前版本：**V3.4.0** (技术栈 Python · LangChain · pywebview/WebView2 · Chroma · Ollama；Qt 已移除)
- 插件体系：内核不可插件化 (脱敏 / 审批 / 审计 / 沙箱)，能力可插件化 (识别 / 解析 / 模板 / 导出)，插件只能"做加法"；详见 [插件开发.md](#)。
- 本文档中出现的个人信息 (张伟 / 13812345678 等) 均为虚构测试样例，不涉及任何真实个人数据。